

CyberDefense Pro 2.0

2.3.3 Security Control Functional Types Facts

This lesson covers the following topics:

- Security control functional types
- Evaluating security controls
- Prioritization and escalation

Security Control Functional Types

Though classified as a category or family, controls can also be described according to the goal or function they perform. The functional control types are:

Type	Description
Preventative	The control acts to eliminate or reduce the likelihood that an attack can succeed, such as system hardening. A preventative control operates before an attack can take place. Access control lists (ACLs) configured on firewalls and file system objects are preventative-type controls. Anti-malware software also acts as a preventative control by blocking processes identified as malicious from executing. Directives, policies, and standard operating procedures (SOPs) are administrative versions of preventative controls. Patch management is generally considered a preventative control when applied proactively to reduce vulnerabilities before they can be exploited. However, in certain circumstances—such as remediating a known vulnerability after discovery—it can serve as a corrective control.
Detective	The control may not prevent or deter access but will identify, record, and report any attempted or successful intrusion. A detective control operates during the progress of an attack. Logs provide one of the best examples of detective-type controls.
Corrective	The control acts to eliminate or reduce the impact of an intrusion event. A corrective control is used after an attack. A good example is a backup system that

Type	Description
	can restore data that was damaged during an intrusion.
Responsive	Responsive controls direct corrective actions enacted after an incident has been confirmed. They are often overlooked and underestimated. A security event can spiral out of control without responsive controls. In a Security Operations Center (SOC), responsive controls might include several very well-defined actions to be taken by an analyst after identifying a specific issue. These actions are often documented in a playbook.
Deterrent	Deterrent controls make the system more difficult to attack and, therefore, decrease attacks. These controls do not prevent access, but discourage attackers from attempting access. Examples could be complex password policies, legal signs, or warnings citing potential repercussions.
Physical	Physical controls such as alarms, security cameras, and lights can deter attackers. Controls such as mantraps and guards can help to prevent attacks.
Compensating	Compensating controls serve as substitutes for principal controls, as recommended by a security standard, and afford the same (or better) level of protection but use a different methodology or technology.

Evaluating Security Controls

While a single security control is not impenetrable, layering various controls can help to delay an attack. As no single security control provides complete protection, each is like a link in a chain, with each control contributing to the overall strength of the chain. A link's weakness impacts the overall effectiveness of the chain. Still, unlike an actual chain, a failure in one control should not result in a complete loss. It might be practical to think of each control type as an individual chain comprised of a series of individual controls of that same type.

The amount of time a particular control can delay an attack is its control efficiency. This is an important measurement when evaluating various controls. However, there are additional factors that many overlook, such as:

Factor	Description
Compatibility	Assess whether the security control works with the existing infrastructure or requires new hardware and software to make it work.
Effectiveness	Will control work well in your environment? If the control is only partially effective or does not provide much benefit, it may not be worth the cost to implement.
Regulations	Consider any regulatory compliance requirements impacted by the control. Make sure you are not breaking any laws.
Policies	Make sure that security control does not violate any company policies.
Feasibility	Consider the feasibility of security control by completing a cost-benefit analysis.

Prioritization and Escalation

Vulnerability response prioritization and escalation are integral to managing security risks. After identifying vulnerabilities, they must be classified according to their severity and potential impact on the organization. Vulnerabilities with the highest severity and potential impact must be prioritized and addressed first. In contrast, those with lower severity and potential implications can be addressed later.

Adopting a functional approach to security control selection allows you to devise a Course of Action (CoA) matrix that maps security controls to known adversary tools and tactics, matching your cybersecurity defensive capabilities to the offensive capabilities of potential cyber adversaries.

It is also essential to ensure that any high-severity vulnerabilities are escalated to all relevant stakeholders to ensure they are informed and can contribute to the response as necessary. Additionally, it is vital to have an established process for escalating vulnerabilities in case the severity of the vulnerability changes or the vulnerability is exploited before remediations are implemented.